

TLP:CLEAR

Выкуп Telegram-юзернейма: от холодного сообщения до поддельного Mini App «Fragment»

Ревизия 1.1 — стадия доставки наблюдаена: цепочка заканчивается дрейнером кошелька, а не перехватом сессии

Social Engineering | Telegram Mini App | TON Connect | Crypto Theft

Параметр	Значение
Даты контактов	20-21 августа 2026
Ревизия	1.1 — 21 августа 2026 (заменяет ред. 1.0 от 20 августа)
Классификация	TLP:CLEAR
Тип	Социальная инженерия -> фишинг через Telegram Mini App (хищение криптоактивов)
Уровень угрозы	СРЕДНИЙ
Цели	Двое исследователей безопасности с публичными Telegram-идентификаторами
Персоны	3 (двое «покупателей», один под видом уведомителя площадки) + инлайн-бот
Компрометация	Не зафиксирована ни по одной из целей

О ревизии

Редакция 1.0 этого отчёта, опубликованная 20 августа 2026 года, описывала единственный холодный контакт и восстанавливала остальную часть цепочки по внешним источникам, прямо оговаривая, что дальнейшая стадия не наблюдалась. В той реконструкции цепочка заканчивалась перехватом сессии Telegram через QR-код или код из SMS, а потерей считался сам аккаунт.

21 августа вторая цель получила ту же приманку, а через шестнадцать минут — недостающую ранее стадию: сообщение, оформленное под уведомление о транзакции Fragment, с кнопкой, открывающей Telegram Mini App. Ссылка на Mini App совпадает по структуре с публично разобранным фишинговым китом под Fragment, финал которого — дрейнер кошелька через TON Connect, а не перехват сессии.

Настоящая ревизия исправляет центральное утверждение редакции 1.0: в этой кампании под ударом прежде всего криптокошелёк, а не Telegram-аккаунт. Угон аккаунта остаётся возможным вариантом того же кита, но перестаёт быть ведущим предположением. Тем, кто действовал по редакции 1.0, следует перечитать раздел 5.

1. Краткое резюме

За 27 часов 20-21 августа 2026 года двое исследователей безопасности с публичными Telegram-идентификаторами получили неспровоцированное предложение выкупить их юзернейм. Заходы пришли с разных аккаунтов и были сформулированы по-разному, но следовали одной схеме: холодное личное сообщение с предложением сделки вокруг Fragment, официальной площадки Telegram для торговли юзернеймами, при этом сама сделка предлагалась в личной переписке, а не через площадку.

Первая цель ответила отказом, и контакт на этом прекратился. Со второй целью операция продолжилась: через шестнадцать минут после первого сообщения третья персона доставила поддельное уведомление площадки с кнопкой подтверждения, ведущей в Telegram Mini App. Ответ цели для этого перехода не потребовался, что указывает на автоматизированный конвейер, а не на ручную работу оператора.

Мы публикуем этот разбор, потому что стадия доставки фиксирует заметный сдвиг: приманка ушла из веба внутрь самого Telegram. Здесь нет домена, адресной строки и TLS-сертификата, которые цель могла бы проверить, и нет ничего, что защищающаяся сторона могла бы заблокировать или отправить на разделение.

2. Хронология

Время (UTC)	Стадия	Событие
20 авг, 08:56	Заход, цель 1	Холодное сообщение от @BlockRider454 с предложением выкупить юзернейм. Ни цены, ни упоминания площадки. Цель ответила отказом,

		продолжения не было.
21 авг, 11:30	Заход, цель 2	Холодное сообщение от персоны с отображаемым именем «NightVelocity» и без юзернейма: «I am offering a deal on the Fragment website. The starting price is 5400 TON. I am open to your offer.»
21 авг, 11:46	Доставка, цель 2	Третья персона с именем «Alert» присылает через инлайн-бота @trinformatbot поддельное «Fragment Official Transaction Notification» с кнопкой «Confirm», открывающей Telegram Mini App.
21 авг, 11:50	Сообщение об инциденте	Цель 2 пересылает оба сообщения на анализ.

Интервал между первым сообщением и доставкой пейлоада составил 15 минут 58 секунд.

3. Стадия доставки

Поддельное уведомление оформлено как сообщение площадки: актив («Telegram Username», «Collectible Username»), тип конвертации («Username в NFT Asset»), блокчейн («TON»), сумма оферты, комиссия площадки 5% и статус «Pending Seller Confirmation». Завершается оно утверждением об эскроу и о необратимости подтверждения. Единственная инлайн-кнопка «Confirm» открывает Mini App с персонализированным под жертву параметром вида <юзернейм>_<сумма>_<комиссия>_Дос4.

Подделку выдают восемь признаков, и их стоит разучить как чеклист — большинство видно без всякого технического анализа:

- В шапке сообщения стоит видимая пометка «via @trinformatbot». Telegram доставляет служебные уведомления только от встроенного аккаунта Telegram (ID 777000), а Fragment — это сайт, который вообще не пишет в личные сообщения.
- Валюта указана неверно и противоречит первому сообщению самой же операции. В личном сообщении фигурировали 5400 TON, в «официальном уведомлении» — 5400 GRAM. GRAM — название так и не выпущенного токена, от которого отказались в 2020 году; расчёты на Fragment идут в TON. Очевидно, что две стадии собраны из разных заготовок.
- «Escrow mechanism» и «Platform Service Fee (5%)» на Fragment не существуют. Строка о комиссии — заготовка под последующее требование предоплаты.
- Рядом с именем персоны-уведомителя стоит синий значок. Это почти наверняка эмодзи-статус Telegram Premium, имитирующий верификацию: по настоящему знаку верификации при нажатии ничего не открывается.
- Персона названа «Alert» и имеет включённую приватность пересылок — она сконструирована так, чтобы выглядеть системным нотификатором и не отдавать свой идентификатор.

- Кнопка открывает Mini App внутри Telegram, а не веб-сайт. Нет ни адресной строки, ни сертификата, ни домена для проверки.
- Параметр ссылки персонализирован под жертву, что указывает на шаблонный конвейер, а не на ручную проработку конкретной цели.
- Текст давит на необратимость и срочность: «permanently converted», «irreversible and cannot be canceled», «Seller confirmation is required to release the funds».

4. Чем цепочка заканчивается на самом деле

Ссылка на Mini App совпадает по структуре с публично разобранным фишинговым китом, имитирующим Fragment внутри Telegram Mini Apps. В открытых разборах зафиксированы родственные боты со ссылками вида `t[.]me/<бот>/start?startapp=<юзернейм>_price_<сумма>` — тот же приём с зашиванием хендла жертвы и суммы в диплинк, чтобы Mini App отрисовал персонализированный экран.

В задокументированных случаях Mini App показывает интерфейс, стилизованный под Fragment, и предлагает подключить TON-кошелёк через TON Connect. Подпись запроса на подключение, а затем транзакции позволяет оператору вывести из кошелька TON, джеттоны и NFT. В одном разобранным экземпляре манифест TON Connect хостился на GitHub, а фишинговый фронтенд отдавался с одноразового домена в зоне .click; инструменты этого класса продаются в готовом виде.

Mini App мы не открывали. Ссылка параметризована хендлом жертвы, поэтому её открытие — равно как и отправка в публичный сканер URL — подтвердило бы оператору, что цель обрабатывается, и раскрыло бы Telegram-идентификатор аналитика через init data приложения. Идентификация выше опирается на структуру ссылки, легенду и оформление, а не на детонированный образец.

5. Исправленная цепочка риска

Редакция 1.0 моделировала потерю так: юзернейм, затем сессия, затем имперсонация.

Наблюдаемый пейлоад указывает на другое. Исправленная цепочка и действия, которые имеют значение на каждом шаге:

Если цель...	Последствие	Что делать
Игнорирует сообщение	Нет	Заблокировать и пожаловаться
Открывает Mini App, но ничего не подключает	Оператор узнаёт, что цель живая, и получает её Telegram ID и имя через init data приложения	Финансовых действий не требуется; заблокировать и пожаловаться
Подключает кошелёк через TON Connect	Само подключение средства не списывает, но у приложения появляется одобренная сессия	Немедленно отозвать подключение в настройках подключённых приложений кошелька
Подписывает любую транзакцию	Из кошелька могут быть выведены TON, джеттоны и NFT	Считать кошелёк скомпрометированным: перевести остатки на кошелёк со свежей seed-фразой
Вводит seed-фразу	Кошелёк потерян полностью	TON Connect никогда не

		запрашивает seed-фразу. Немедленно мигрировать все активы
Конвертирует юзернейм в NFT «чтобы завершить сделку»	Хендл необратимо становится передаваемым активом	Не выполнять этот шаг: это единственное действие, которое жертва совершает на настоящем сайте

6. Почему публичные идентификаторы — особый случай

Финансовая рамка выше не отменяет репутационных рисков, описанных в редакции 1.0. Тот же кит может быть настроен на захват аккаунта, а не кошелька, и для того, кто использует Telegram как рабочий канал связи с источниками, журналистами и НКО, именно этот вариант опаснее.

- Реальная потеря — доверие к идентификатору. Тот, кто контролирует аккаунт, может писать источникам и партнёрским организациям от имени владельца.
- Доступ к истории переписки — это доступ к источникам: он позволяет деанонимизировать контакты и раскрыть методы сбора.
- Опубликованный юзернейм сам по себе является списком целей, никакой дополнительной разведки не требуется.
- Кампания может быть полностью нецелевой и всё равно наносить непропорциональный ущерб, когда попадает на заметный аккаунт.

7. Индикаторы

Тип	Значение
Telegram username	@BlockRider454
Telegram display name	BlockRider
Telegram bio	Collector of usernames
Telegram display name	NightVelocity
Telegram user ID	8576276249
Telegram display name	Alert
Telegram bot	@trininformbot
Telegram bot ID	8986655554
Telegram bot display name	Trades
Ссылка на Mini App (шаблон)	hxxps://[.]me/trininformbot/start?startapp=<юзернейм>_<сумма>_<комиссия>_Do c4
SHA-256 (аватар бота)	c306dddfcbc88af28435a826a70310f82faf7d281fa18ebf4e931b8fcacafe1e

Юзернеймы и отображаемые имена — наименее устойчивые из этих индикаторов: Telegram позволяет менять и переиспользовать хендлы. Числовые идентификаторы переживают такую

ротацию и являются устойчивой точкой опоры. Отметим, что свой ID раскрыла только одна из трёх персон — у остальных двух приватность пересылок была включена. Это само по себе полезное наблюдение: пул аккаунтов оператора настроен неоднородно.

Все три персоны сменили отображаемое имя и фотографию профиля в пределах одного окна в июне 2026 года, примерно за два месяца до кампании. Это указывает на пул отслежившихся аккаунтов, перепрофилированных под операцию, а не на аккаунты, зарегистрированные ради неё.

Ещё два бот-хендла, @FragmentOffersRoBot и @SendingOffersBot, фигурируют в сторонних разборах того же кита. Они приведены здесь как контекст, а не как наше собственное наблюдение.

8. MITRE ATT&CK

ID	Техника
T1585.001	Establish Accounts: Social Media Accounts — пул персон, перепрофилированный под кампанию
T1656	Impersonation — поддельное уведомление площадки Fragment и имитация знака верификации
T1598.003	Phishing for Information: Spearphishing via Service — холодный заход в личные сообщения Telegram
T1566.003	Phishing: Spearphishing via Service — пейлоад доставлен сообщением инлайн-бота с кнопкой-ссылкой
T1204.001	User Execution: Malicious Link — жертва должна сама открыть Mini App
T1657	Financial Theft — вывод средств через TON Connect после подписи транзакции

9. Рекомендации

9.1. Если вы это получили

- Не нажимайте кнопку подтверждения и не открывайте Mini App из любопытства — ссылка идентифицирует вас перед оператором.
- Никогда не подключайте кошелек и не подписывайте транзакции по ссылке из личного сообщения. Seed-фразу нельзя вводить ни в какое Mini App: TON Connect её не запрашивает.
- Если кошелек подключался — отзовите подключение в настройках подключённых приложений. Если что-то подписывалось — переведите активы на кошелек с новой seed-фразой.
- Не конвертируйте юзернейм в NFT, чтобы «завершить» сделку, предложенную в переписке.
- Заблокируйте отправителя и бота и отправьте жалобу.

9.2. Постоянная гигиена

- Считайте поддельным любое сообщение в Telegram, выдающее себя за уведомление площадки, если оно содержит пометку «via @бот» или кнопку. Настоящие уведомления приходят только от аккаунта Telegram (ID 777000).
- Продавайте юзернейм только через Fragment. Настоящему покупателю незачем договариваться в личке.

- Включите двухэтапную аутентификацию с облачным паролем и не полагайтесь только на SMS.
- Периодически проверяйте активные сессии и завершайте все посторонние при любом неожиданном коде входа.
- Скройте номер телефона и ограничьте звонки и добавление в группы только контактами.
- Держите отдельный канал восстановления: почту с 2FA или passkey, а не только номер телефона.

9.3. Для организаций и сетей контактов

- Заранее договоритесь о запасном способе подтверждения личности — кодовом слове или втором канале связи. Это делается до инцидента, а не после.
- Проверяйте любое необычное сообщение от известного контакта по другому каналу, особенно если в нём просят денег, ссылку или данные.

10. Источники

- p05h, «Sophisticated Telegram Based Scam Designed to Fool Fragment Users», Medium, 2024-11
- «The Telegram Username Scam: How People Are Losing Thousands in TON», LearnHub / DEV Community, 2025-07
- DecentParadox, «Telegram Fragment Scam» — шаблон startapp-ссылки родственных ботов
- ton-blockchain/ton-connect, issue #104, «phishing page leads to drainer with ton connect link»
- «Telegram Mini Apps Abused in FEMITBOT Crypto Scam», Malaysian Wireless, 2026-05
- Собственные наблюдения авторов, 20-21 августа 2026 года

TLP:CLEAR — Этот документ может распространяться без ограничений.